

Stoquify Supplier Workflow Remediation Plan

Generated: 2026-08-08 Objective: Close the remaining supplier-workflow readiness gaps identified in the latest review and stabilize enterprise-readiness.

1. Immediate controls (P1/P0 equivalent: none found in this run)

No P1/P0 defects were identified for the supplier workflow in this execution.

2. Priority remediation (P2 / P3)

P2-1: Redact or mask sensitive supplier fields in exported outputs

- **Evidence:** `components/suppliers/SupplierManagementDashboard.tsx` currently writes raw contact fields into CSV (`contactPerson` , `email` , `phone` , `taxId`) before download.
- **Action:** Add a redaction policy toggle:
 - Default export for most roles: omit `email` , `phone` , `taxId` .
 - Advanced admin role: include when explicitly enabled.
 - Add a warning label in UI that export is sensitive.
- **Owner:** Frontend team + Product security reviewer
- **Effort:** 1 day
- **Acceptance:**
 - Export file no longer contains sensitive fields by default.
 - Role-specific export intent is auditable and intentional.

P2-2: Add supplier export and clipboard security tests

- **Evidence gap:** No unit/e2e assertion currently proves redaction policy or minimal-copy behavior.
- **Action:** Add tests to assert:
 - `exportSuppliers` payload excludes masked fields for default roles.
 - `copySupplierId` remains functional without exposing additional secret metadata.
- **Owner:** QA + Frontend test engineering
- **Effort:** 1 day
- **Acceptance:** Test suite includes a minimum of 2 assertions around export minimization and clipboard behavior.

P2-3: Add management-flow tests for supplier archive/deactivate semantics

- **Evidence gap:** Current `services/supplier/__tests__/supplier.service.test.ts` focuses on item-supplier junction behavior, not archive/deactivate branch decisions.
- **Action:** Add tests for:
 - `removeSupplierForManagement` returning `archived` when no history exists.
 - `removeSupplierForManagement` returning `deactivated` when history exists.
- **Owner:** Backend/domain owner
- **Effort:** 0.5 day
- **Acceptance:** New tests for both branches passing.

3. Follow-up hardening (non-blocking but recommended)

- Add structured event logging for supplier CSV export and supplier archive actions with actor/tenant context.
- Add UX clarifications in supplier analytics path to avoid accidental over-exposure when opening CSV with large datasets.

4. Stop condition

Declare this queue complete when:

1. export redaction controls are implemented with role-aware policy,
2. tests validating redacted output are added,
3. archive/deactivate branch tests are added,
4. `npm run test`, `npm run typecheck`, `npm run lint` pass.